

Game Of Active Directory v2

mayfly277.github.io/posts/GOADv2

July 1, 2022



The second version of Game Of Active directory is out! <https://github.com/Orange-Cyberdefense/GOAD>

I spent months to setup this new lab, with a bunch of new features and the result is finally available.

With this new lab i worked to add the following features:

- Multi domains and multi forest:
 - Now there is child/parent domain with sevenkingdoms.local and north.sevenkingdoms.local
 - A separate forest as essos.local to train the forest to forest technics
- IIS :

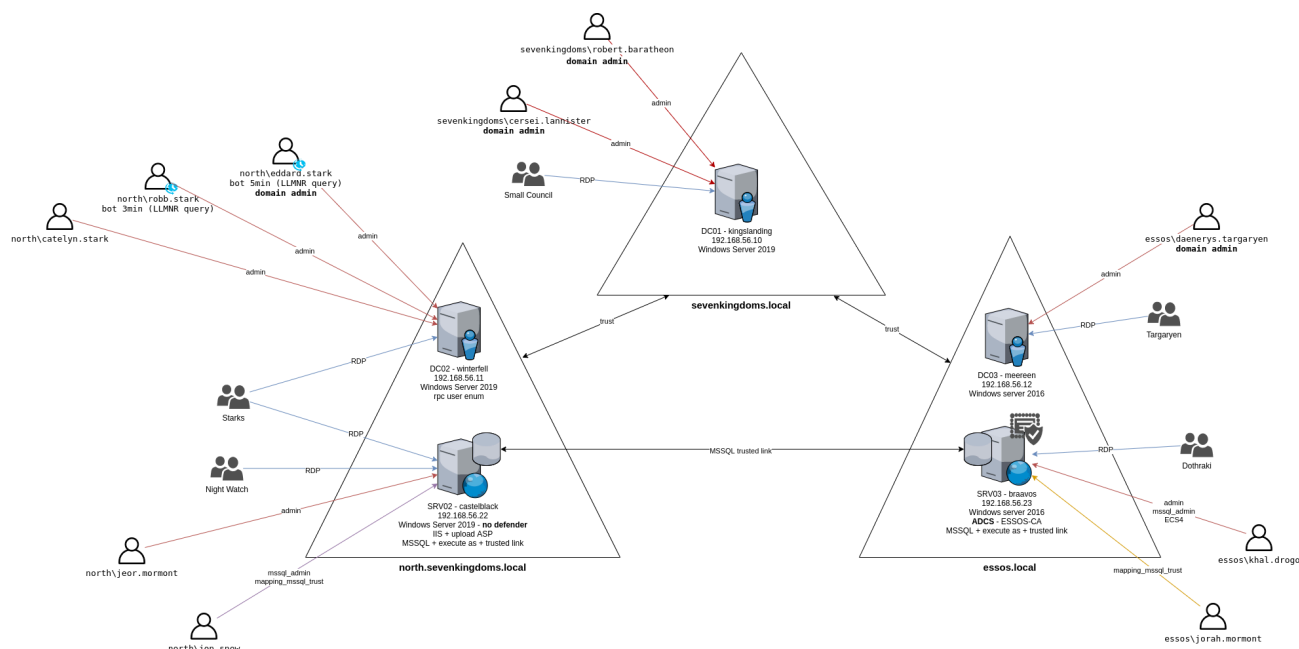
An IIS server is available on castelblack.north.sevenkingdoms.local with the ability to upload asp to get a shell

- MSSQL :
 - Two MSSQL servers are now available, one in `castelblack.north.sevenkingdoms.local` and another on `braavos.sevenkingdoms.local`
 - The two servers are linked to test MSSQL trusted link.
 - Impersonation configuration are also set up on the MSSQL server
- Anonymous user listing:

An anonymous user listing is now available in `winterfell.north.sevenkingdoms.local`
- ADCS :

One of the biggest improvement of v2 with the multi domains is that an ADCS server is available on `essos.local` and with miss configurations to try at least `esc1` to `3` and `esc8`.

An other view of the lab can be resumed with this chart:



The global technics available on the lab are:

- Password reuse between computers (PTH)
- Spray User = Password
- Password in description
- SMB share anonymous
- SMB not signed
- Responder
- Zerologon
- Windows defender
- ASREPRoast
- Kerberoasting
- AD Acl abuse (forcechangepassword, genericall, genericwrite,...)

- Unconstraint delegation
- Ntlm relay
- Constrained delegation
- MSSQL exec
- MSSQL trusted link
- MSSQL impersonate
- IIS service to Upload malicious asp
- Multiples forest
- Anonymous RPC user listing
- Child parent domain escalation
- Certificate and Idaps available
- ADCS - ESC 1/2/3/8
- Certify
- Samaccountname/nopac
- Petitpotam unauthent
- Printerbug
- Drop the mic
- Shadow credentials
- Printnightmare
- Krbrelayup
- ...

I will details those on various blog post writeup on the GOAD lab exploitation.

Installation

- First you need a big computer to get the lab up and running. Mine is a 8cpu/32Go RAM.
- Maybe a 4CPU/16Go could be enough but I am really not sure about it as there is 5 windows VM to launch!

```
git clone https://github.com/Orange-Cyberdefense/GOAD.git
```

We start by launching vagrant to get all the vms and let vagrant provide them

- Once we get all the vms up and running it's time to provision them with ansible
- We install all the needed packages and launch the main.yml playbook

```
sudo apt install python3.8-venv
cd ansible
python3.8 -m virtualenv .venv
source .venv/bin/activate
python3 -m pip install --upgrade pip
python3 -m pip install ansible-
core==2.12.6
python3 -m pip install pywinrm
ansible-galaxy install -r
requirements.yml
ansible-playbook main.yml
```

If there is error we just re-launch `ansible-playbook main.yml` until there is no failure during the installation.

Lab running

We check the lab with cme

```
cme smb
192.168.56.0/24
```

```
[Jul 03, 2022 - 16:19:14 (CEST)] exegol-goadv2 /workspace # cme smb 192.168.56.0/24
SMB      192.168.56.23  445  BRAAVOS      [*] Windows Server 2016 Standard Evaluation 14393 x64 (name:BRAAVOS) (domain:essos.local) (signing:False) (SMBv1:True)
SMB      192.168.56.11  445  WINTERFELL   [*] Windows 10.0 Build 17763 x64 (name:WINTERFELL) (domain:north.sevenkingdoms.local) (signing:True) (SMBv1:False)
SMB      192.168.56.12  445  MEEREEN      [*] Windows Server 2016 Standard Evaluation 14393 x64 (name:MEEREEN) (domain:essos.local) (signing:True) (SMBv1:True)
SMB      192.168.56.22  445  CASTELBLACK  [*] Windows 10.0 Build 17763 x64 (name:CASTELBLACK) (domain:north.sevenkingdoms.local) (signing:False) (SMBv1:False)
SMB      192.168.56.10  445  KINGSLANDING [*] Windows 10.0 Build 17763 x64 (name:KINGSLANDING) (domain:sevenkingdoms.local) (signing:True) (SMBv1:False)
```

All is ok, let's start to pwn the lab : [Goad pwning part1](#)